POLICY BRIEF

Sovranità Digitale nella Pubblica Amministrazione Italiana

Osservatorio Nazionale Sovranità Digitale — Giugno 2025

Il problema

La Pubblica Amministrazione italiana dipende in misura significativa da infrastrutture digitali gestite da provider soggetti a giurisdizioni extra-europee. Questa dipendenza espone le comunicazioni istituzionali e i dati dei cittadini a rischi concreti di accesso da parte di autorità straniere, in particolare attraverso il CLOUD Act statunitense (2018), e si pone in potenziale contrasto con il GDPR e le sentenze della Corte di Giustizia dell'UE (Schrems I e II). In particolare, gli artt. 48 e 115 del GDPR vietano di dare seguito a ordini di autorità extra-UE non fondati su accordi internazionali: a determinare la giurisdizione è la nazionalità del fornitore, non la sede fisica del dato.

L'AMMISSIONE DI MICROSOFT

«No, non posso garantirlo.»

Il Direttore degli Affari Pubblici e Legali di Microsoft France, richiesto in audizione se potesse garantire che i dati dei cittadini europei non venissero trasferiti al governo statunitense in virtù di un ordine emesso ai sensi del CLOUD Act — senza l'accordo delle autorità nazionali. È Microsoft stessa ad ammettere di non poter escludere il trasferimento dei dati europei alle autorità USA.

Anton Carniaux, Direttore Affari Pubblici e Legali, Microsoft France — Audizione, Commissione d'inchiesta del Senato francese, 10 giugno 2025. Fonti: Senato francese (senat.fr) · heise.de

I numeri

- ~23.000 enti PA monitorati (fonte IndicePA)
- I servizi email sono il primo ambito analizzato
- La mappatura copre tutti i domini istituzionali registrati
- I dati sono raccolti e aggiornati tramite analisi automatica dei record MX
- Il dataset è aperto, verificabile e rilasciato sotto licenza CC BY-SA 4.0

Il contesto normativo

Il quadro normativo europeo e italiano impone obblighi precisi sulla localizzazione e protezione dei dati della PA:

Norma	Rilevanza
GDPR (Reg. UE 2016/679)	Vieta trasferimenti dati verso paesi terzi senza garanzie adeguate
Schrems II (CGUE, 2020)	Ha invalidato il Privacy Shield UE-USA
CLOUD Act (USA, 2018)	Consente accesso USA a dati di provider americani anche in UE
Strategia Cloud Italia (2021)	Classifica i dati PA e prevede migrazione verso infrastrutture qualificate
NIS2 (Dir. UE 2022/2555)	Requisiti cybersecurity per PA e soggetti essenziali

Il costo economico della dipendenza

Alla questione giuridica se ne affianca una economica, finora assente dal dibattito italiano. Due studi della società Asterès, commissionati dal Cigref, provano a quantificarla a scala europea. Le imprese dell'Unione acquistano ogni anno 264 miliardi di euro di servizi cloud e software a beneficio dell'economia americana — circa l'1,5% del PIL dell'Unione e una volta e mezza il bilancio europeo. I fornitori statunitensi valgono l'83% del

mercato europeo del settore. Poiché le importazioni europee di energia sono valse 360 miliardi nel 2024, la bolletta digitale dell'Europa è ormai comparabile alla sua bolletta energetica.

Il secondo studio misura la dinamica dei prezzi: +8,7% annuo negli ultimi tre anni, +12% atteso nei prossimi cinque, con un aumento medio del 51% al rinnovo di contratto e casi estremi dichiarati fino al 200-300%. Il sovrapprezzo stimato è di 140 miliardi l'anno al 2030, dei quali 93 uscirebbero definitivamente dal continente. Gli aumenti sono giustificati con funzionalità di intelligenza artificiale imposte nel 40% dei casi, mentre circa il 60% degli intervistati giudica teorici i relativi guadagni di produttività.

Come vanno letti questi numeri. Non sono misurazioni ma stime estrapolate da interviste a sei Chief Information Officer, perché i dati commerciali sono distorti dal peso dell'Irlanda nei flussi; e il Cigref è parte interessata. Lo studio dichiara metodo e limiti, e vanno citati per quello che sono. Restano, allo stato, il solo ordine di grandezza disponibile — e indicano che la dipendenza non è soltanto un rischio giuridico, ma una voce di spesa crescente e non negoziata.

La via d’uscita: certificare l’immunità

La distinzione decisiva è una sola. La residenza del dato e gli impegni contrattuali non tolgono la giurisdizione: un data center in Italia e clausole di riservatezza non sottraggono un fornitore statunitense al CLOUD Act. A determinare la giurisdizione è il controllo societario di chi opera il servizio. L’unica misura che la rimuove è che il servizio sia operato da un’entità europea autonoma — e questo è un requisito che si può certificare.

SecNumCloud 3.2 (ANSSI, Francia) è oggi l’unico schema nazionale europeo che richiede esplicitamente l’immunità dalle legislazioni extraterritoriali e il controllo europeo del capitale: esclude quindi in modo strutturale, e non solo contrattuale, l’applicazione del CLOUD Act. Risultano qualificati OVHcloud e S3NS (Thales, su tecnologia Google, qualificata il 17 dicembre 2025); Bleu (Orange e Capgemini su tecnologia Microsoft) è in corso di qualificazione.

La qualificazione italiana dei servizi cloud per la PA non prevede una clausola equivalente. L’Osservatorio ha esaminato il testo integrale del Decreto Direttoriale ACN 21007/24 — 88 pagine, tutti e quattro gli allegati: le espressioni «extraterritoriale», «CLOUD Act», «nazionalità», «sede legale», «capogruppo», «capitale» e «paese terzo» non vi compaiono mai. Lo schema è costruito su classificazione dei dati, misure di sicurezza e localizzazione, non sul controllo societario dell’operatore. L’unica disposizione sul tema, limitata ai dati strategici, impone al fornitore di segnalare le richieste di accesso provenienti da entità extra-UE: è un obbligo procedurale che presuppone l’accesso invece di escluderlo, ed è ineseguibile proprio nel caso per cui è previsto, perché un ordine accompagnato da gag order vieta al fornitore quella stessa segnalazione.

A livello europeo gli stessi criteri di immunità hanno un nome: «High+». Non sono mai stati un livello formale — il Cybersecurity Act ne prevede tre — ma l’etichetta negoziale dei criteri di immunità, rimossi dallo schema EUCS nel marzo 2024 e mai reintrodotti. Nel giugno 2026 la Commissione europea afferma che l’EUCS «non è ancora stato adottato»: nessun atto giuridico, nessun certificato emesso. La sovranità è riemersa altrove, nei livelli di affidabilità dell’Unione previsti dalla proposta di Cloud and AI Development Act, il cui livello più alto riprende in sostanza i requisiti mancati — ma vincola gli appalti pubblici, non il mercato, ed è ancora una proposta. È uno schema volontario: non esclude alcun fornitore dal mercato e non impone nulla agli acquirenti, offre soltanto un’alternativa certificata a chi ne ha bisogno. L’inclusione dei criteri High+ è stata chiesta da 62 organizzazioni, in un’iniziativa coordinata da Airbus e composta in larga parte da utenti — banche, assicurazioni, industria della difesa — tra cui gli italiani Leonardo, Fincantieri, Generali e Telecom Italia. Il dato rilevante non è un giudizio su quelle imprese: è che la domanda di immunità esiste e viene dall’industria italiana, mentre manca la risposta normativa italiana.

Il modello, infine, non richiede di abbandonare i fornitori statunitensi ed è già realtà. Microsoft opera national cloud separati dove un governo lo ha preteso: negli Stati Uniti con Microsoft Cloud for US Government e in Cina, dove la tecnologia è licenziata a 21Vianet, che gestisce il servizio in autonomia — «Microsoft is the technology provider, but Microsoft doesn’t operate the service». In Francia la stessa impostazione ha prodotto Bleu e S3NS. Ciò che cambia non è la tecnologia, ma chi opera il servizio.

Raccomandazioni di policy

1. Introdurre un requisito di immunità dalle legislazioni extra-UE nello schema di qualificazione italiano dei servizi cloud per la PA, sul modello di SecNumCloud 3.2.
2. Sostenere l’inclusione dei criteri High+ nell’EUCS nelle sedi europee competenti (ECCG, Commissione europea), esplicitando la posizione italiana.
3. Usare la domanda pubblica come leva: prevedere il requisito di immunità nelle convenzioni e negli appalti che riguardano dati critici e strategici.
4. Non serve escludere i fornitori statunitensi: serve richiedere che il servizio sia operato da un’entità europea autonoma.

Raccomandazioni

1. Censimento obbligatorio dei servizi digitali della PA

Rendere obbligatoria la dichiarazione dei servizi digitali utilizzati da ogni ente e della relativa giurisdizione. Integrare questa informazione nell’IndicePA per renderla pubblica e monitorabile.

2. Requisiti di sovranità nelle convenzioni Consip

Inserire criteri di sovranità digitale (giurisdizione dati, localizzazione server, assenza obblighi verso autorità extra-UE) nelle convenzioni per servizi email e cloud.

3. Piano nazionale di migrazione

Definire un piano con scadenze progressive per la migrazione dei servizi email della PA verso provider conformi. Prevedere fondi dedicati dal PNRR o dalla cybersecurity.

4. Monitoraggio continuo e trasparente

Istituzionalizzare il monitoraggio della sovranità digitale della PA con dati pubblici e aggiornati periodicamente.

5. Promozione del modello a livello europeo

Proporre nelle sedi europee l'adozione di un framework comune per il monitoraggio della sovranità digitale delle PA in tutti gli stati membri.

Cosa puoi fare

Se sei un parlamentare: Presenta un'interrogazione citando i dati dell'Osservatorio. Proponi l'inserimento di requisiti di sovranità nella normativa.

Se sei un dirigente PA: Verifica la posizione del tuo ente e avvia una valutazione interna sulla migrazione.

Se sei un regolatore: Utilizza i dati per aggiornare le linee guida e inserire requisiti nelle convenzioni.

Fonti e riferimenti

- Osservatorio Nazionale Sovranità Digitale: https://osservatorio.mxmap.it/
- MxMap.it — Mappatura provider email PA: https://mxmap.it/
- IndicePA — Indice delle Pubbliche Amministrazioni: https://indicepa.gov.it
- GDPR: Regolamento UE 2016/679
- Sentenza Schrems II: CGUE C-311/18

Questo documento è rilasciato sotto licenza CC BY-SA 4.0. Contatti: github.com/mxmap-it/osservatorio-nazionale-sovranita-digitale